

ENTERPRISE SECURITY ASSESSMENT LAB

PACU PRIVILEGE ESCALATION SCAN

Professional methodology report for AWS IAM privilege escalation path analysis

Module	Cloud Security Assessment
Document Type	Individual Methodology Report
Phase	Phase 3
Evidence Source	pacu-privesc-scan-results.png
Publication Type	GitHub Portfolio - Redacted Lab Version
Prepared For	04-cloud-security/README.md documentation set
File Name	03-pacu-privilege-escalation-scan-methodology-report.pdf

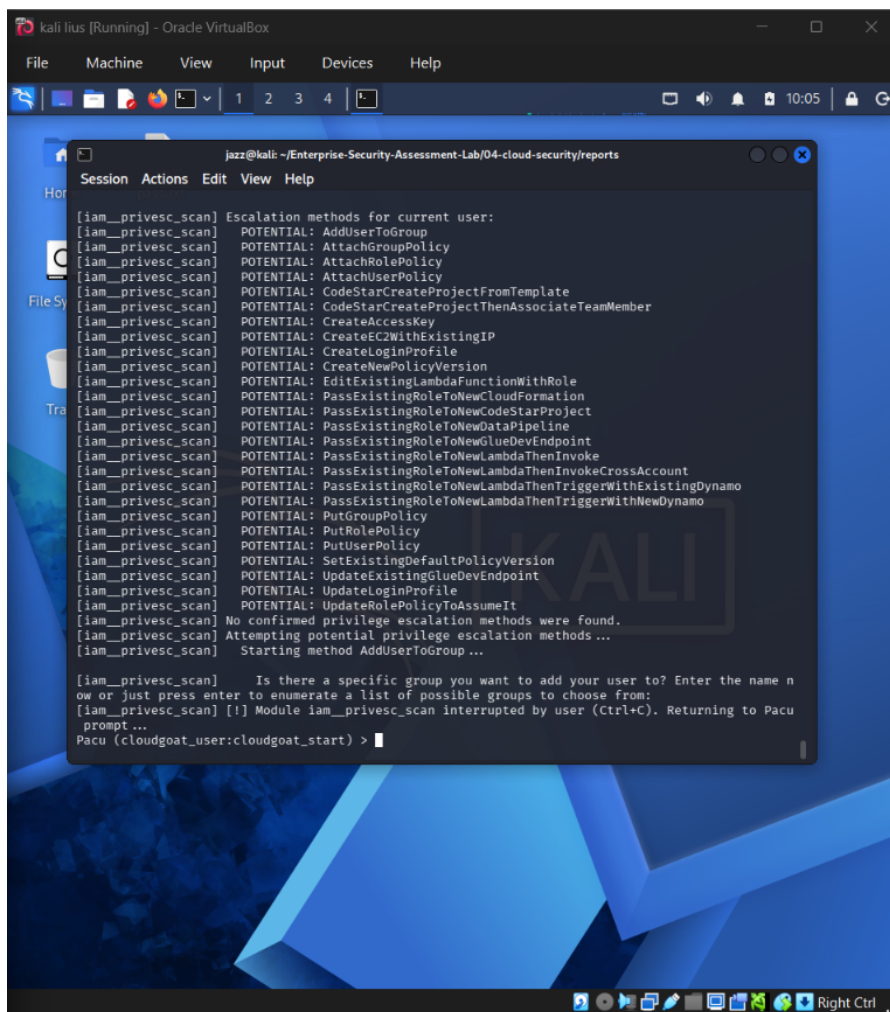
1. Executive Purpose

Pacu was used to automate privilege escalation path review. The goal is not to attack a real cloud account, but to demonstrate how cloud testers identify risky IAM permission combinations in a controlled lab environment.

2. Scope and Evidence Mapping

Testing objective	Use Pacu to identify potential AWS IAM privilege escalation paths from the current CloudGoat/lab identity.
Cloud platform	Amazon Web Services (AWS)
Lab context	CloudGoat / authorized vulnerable cloud lab environment
Primary tools	Pacu, AWS CLI profile, IAM privilege escalation module
Evidence file(s)	pacu-privesc-scan-results.png
Result type	IAM privilege escalation analysis completed

3. Embedded Evidence Screenshot(s)



```
jazz@kali: ~/Enterprise-Security-Assessment-Lab/04-cloud-security/reports
Session Actions Edit View Help

[iam__privesc_scan] Escalation methods for current user:
[iam__privesc_scan] POTENTIAL: AddUserToGroup
[iam__privesc_scan] POTENTIAL: AttachGroupPolicy
[iam__privesc_scan] POTENTIAL: AttachRolePolicy
[iam__privesc_scan] POTENTIAL: AttachUserPolicy
[iam__privesc_scan] POTENTIAL: CodeStarCreateProjectFromTemplate
[iam__privesc_scan] POTENTIAL: CodeStarCreateProjectThenAssociateTeamMember
[iam__privesc_scan] POTENTIAL: CreateAccessKey
[iam__privesc_scan] POTENTIAL: CreateEC2WithExistingIP
[iam__privesc_scan] POTENTIAL: CreateLoginProfile
[iam__privesc_scan] POTENTIAL: CreateNewPolicyVersion
[iam__privesc_scan] POTENTIAL: EditExistingLambdaFunctionWithRole
[iam__privesc_scan] POTENTIAL: PassExistingRoleToNewCloudFormation
[iam__privesc_scan] POTENTIAL: PassExistingRoleToNewCodeStarProject
[iam__privesc_scan] POTENTIAL: PassExistingRoleToNewDataPipeline
[iam__privesc_scan] POTENTIAL: PassExistingRoleToNewGlueDevEndpoint
[iam__privesc_scan] POTENTIAL: PassExistingRoleToNewLambdaThenInvoke
[iam__privesc_scan] POTENTIAL: PassExistingRoleToNewLambdaThenInvokeCrossAccount
[iam__privesc_scan] POTENTIAL: PassExistingRoleToNewLambdaThenTriggerWithExistingDynamo
[iam__privesc_scan] POTENTIAL: PassExistingRoleToNewLambdaThenTriggerWithNewDynamo
[iam__privesc_scan] POTENTIAL: PutGroupPolicy
[iam__privesc_scan] POTENTIAL: PutRolePolicy
[iam__privesc_scan] POTENTIAL: PutUserPolicy
[iam__privesc_scan] POTENTIAL: SetExistingDefaultPolicyVersion
[iam__privesc_scan] POTENTIAL: UpdateExistingGlueDevEndpoint
[iam__privesc_scan] POTENTIAL: UpdateLoginProfile
[iam__privesc_scan] POTENTIAL: UpdateRolePolicyToAssumeIt
[iam__privesc_scan] No confirmed privilege escalation methods were found.
[iam__privesc_scan] Attempting potential privilege escalation methods ...
[iam__privesc_scan] Starting method AddUserToGroup ...

[iam__privesc_scan] Is there a specific group you want to add your user to? Enter the name n
ow or just press enter to enumerate a list of possible groups to choose from:
[iam__privesc_scan] [!] Module iam__privesc_scan interrupted by user (Ctrl+C). Returning to Pacu
prompt ...
Pacu (cloudgoat_user:cloudgoat_start) > |
```

Figure 1 - Pacu iam__privesc_scan output listing potential escalation methods in the lab.

4. Methodology and Execution Workflow

The tester starts Pacu, imports the CloudGoat/lab profile keys, sets the region, confirms identity with whoami, and runs the iam__privesc_scan module. The output is reviewed for potential methods such as policy attachment, login profile creation, key creation, PassRole abuse, and service-linked escalation paths.

Command / workflow used

```
pacu
import_keys cloudgoat
set_regions
us-east-1
whoami
run iam__privesc_scan
```

Execution notes

- Run Pacu only in an authorized lab account.
- Review results as potential escalation methods, not automatically confirmed exploitation.
- Document interrupted or rejected methods honestly.
- Use the results to prioritize IAM remediation.

5. Sanitized Tool Output Style

The following output example is sanitized. It documents the expected evidence style without exposing AWS account IDs, ARN values, AccessKeyId values, SecretAccessKey values, session tokens, private bucket names, or billing details.

```
[iam__privesc_scan] Escalation methods for current user:
[+] POTENTIAL: AttachUserPolicy
[+] POTENTIAL: CreateAccessKey
[+] POTENTIAL: PassExistingRoleToNewEC2
[+] POTENTIAL: CreatePolicyVersion
```

No sensitive account values are required for publication.

6. Professional Interpretation

The screenshot demonstrates that Pacu identified multiple potential escalation paths. This is strong evidence of practical cloud security testing because it shows both tool operation and understanding of IAM attack-path logic.

7. Risk Analysis

Risk Area	Explanation
Low-to-high privilege path	Cloud privilege escalation can transform a constrained user into a more powerful role.
Automation risk	Attackers can automate IAM review quickly using public tools.
Misconfiguration visibility	Pacu highlights risky combinations that may be missed in manual reviews.

8. Defensive Recommendations

- Remove unnecessary privilege-sensitive permissions.
- Restrict iam:PassRole, iam:AttachUserPolicy, iam:CreateAccessKey, iam:CreatePolicyVersion, and sts:AssumeRole.
- Use permission boundaries and SCPs for guardrails.
- Alert on unusual IAM changes and new access keys.

- Review CloudTrail for policy modification and role-passing events.

9. GitHub Redaction and Publication Guidance

Before publishing this document or the underlying screenshot evidence, verify that the following values are removed, blurred, or replaced with placeholders. This is especially important because cloud evidence can contain values that are valid beyond the lab session if not rotated or destroyed.

Sensitive value	Required handling
AWS Account ID	Blur or replace with <REDACTED_ACCOUNT_ID>.
ARN values	Redact account number and private role/user names where needed.
AccessKeyId / SecretAccessKey	Must never be visible. Rotate immediately if exposed.
SessionToken	Must be fully redacted because temporary credentials can still be abused during validity period.
Bucket names / resource names	Redact if they identify private infrastructure or are still active.

10. Evidence Quality Checklist

- The screenshot is readable and aligned within the page margins.
- The evidence filename matches the GitHub link exactly.
- The command/output supports the stated result type.
- No AWS credentials, session tokens, account numbers, or private resource identifiers are visible.
- The report explains both the offensive testing value and the defensive remediation value.